

Capítulo 5

Levantamento de Informações

5.1. Objetivos

- Conhecer os principais meios para coletar informações sobre o alvo
- Coletar informações utilizando ferramentas públicas
- Coletar informações utilizando ferramentas específicas
- Levantar domínios utilizando consultas públicas e ferramentas

5.2. Footprint

Footprint é a primeira etapa a ser realizada em um teste de intrusão. Durante essa etapa, o Pen-tester coleta o máximo de informações para alimentar a anatomia de ataque. Podemos dizer que é a fase em que o Pen-tester se prepara para realizar o ataque.

Em média, um Pen-tester gasta 70% do tempo analisando um alvo e levantando informações sobre o mesmo. Apenas 30% do tempo é usado para realizar o ataque e avaliar a possibilidade de um atacante realizar procedimentos pós-invasão na máquina alvo.

Quando estamos realizando um footprint, devemos buscar informações relativas à topologia da rede, sistemas operacionais, quantidade de máquinas e localização física. Além disso, é importante também descobrir informações sobre os funcionários da empresa, como: emails, cargos e também função específica no ambiente.

"Dê-me seis horas para cortar uma árvore, e eu gastarei as primeiras quatro horas afiando o machado."

Abraham Lincoln

5.3. Por onde começar?

O primeiro passo para começar a coleta de informações é navegar no website do alvo. Vamos tomar como exemplo o website que hospeda o kernel Linux. Abra o navegador e aponte para <http://www.kernel.org>.

Que tipo de informações você conseguiu encontrar no site?

Neste site há pelo menos três informações que um cracker levaria em consideração:

- Dois e-mails válidos

- Um endereço para acompanhar as estatísticas dos servidores
- E uma lista com tecnologias e fornecedores

Não acredita? Então de uma olhada:

Os e-mails são `webmaster@kernel.org` e `ftpadmin@kernel.org`

`http://cacti.kernel.org/graph_view.php?action=preview`

`http://www.kernel.org/powered.html`

Ainda não encontrou? Então experimente olhar o código fonte da aplicação!

Como vimos, um simples acesso e um pouco de observação no site do alvo pode nos fornecer algumas informações no mínimo interessantes. Depois de observar um website à procura de informações, o próximo passo é pesquisar sobre coisas não tão óbvias, porém, ainda sim públicas.

5.4. Consulta a informações de domínio

Após observar o site do alvo, é de interesse do atacante conhecer detalhes referentes ao nome de domínio do cliente. A primeira coisa a ser feita é buscar informações sobre o proprietário de um domínio. Isso pode ser feito utilizando o comando `whois`.

```
#whois oys.com.br
```

Podemos concluir que com um simples comando, disponível em praticamente qualquer sistema operacional, foi possível obter o nome do responsável pelo domínio, o nome do responsável técnico pelo domínio, o nome dos dois servidores de DNS e o CNPJ da empresa, localizado no campo `ownerid`.

Além da consulta `whois` em sistemas operacionais, é possível ainda utilizar serviços que consultam o a base de dados de proprietários de domínios através de ferramentas web, como o próprio `http://registro.br`, por exemplo.



<https://registro.br/cgi-bin/whois/>

Se compararmos a saída do site com a saída do comando `whois`, veremos que o resultado é idêntico.

É importante saber que para cada região do mundo inteiro, há organizações responsáveis pelo registro de domínios, acima das organizações responsáveis pelos registros em cada país.

No quadro abaixo, temos o nome e o endereço das organizações responsáveis em cada parte do globo pelo gerenciamento e liberação de domínio (incluindo o grupo de IPs) para cada região:

Registry Acronym	Registry Name	Web Site
ARIN	American Registry for Internet Numbers	www.arin.net/
RIPE	Réseaux IP Européens	www.ripe.net/
APNIC	Asia Pacific Network Information Centre	www.apnic.net/
AFRINIC	African Network Information Centre	www.afrinic.net/
LACNIC	Latin America & Caribbean Network Information Centre	www.lacnic.net/

5.5. Consultando servidores DNS

Como sabemos, os servidores DNS são responsáveis por traduzir os nomes canônicos de um domínio para o seu respectivo endereço IP. Sendo assim, um servidor DNS conhece todos servidores que estão acessíveis através da rede pública. Vamos consultá-lo, então.



```
dig -t MX oys.com.br  
dig -t NS oys.com.br
```

Os campos MX, e NS fornecem, respectivamente, o nome dos servidores de e-mail e o nome de todos os servidores de DNS.

Com essa consulta, já conseguimos, inclusive, endereços de servidores que utilizaremos em nossa varredura e enumeração de serviços.

5.6. Consultando websites antigos

Além da possibilidade de utilizarmos a opção em cache do Google, é possível utilizarmos outros serviços que possibilitam que acessemos versões mais antigas de qualquer site que já tenha sido publicado na web.



<http://www.archive.org>

Com isso, podemos encontrar informações que podem ser úteis, principalmente para ataques de engenharia social, pois encontramos produtos antigos, ex-funcionários, informações que foram retiradas do site por serem sensíveis e etc.

5.7. Webspiders

Webspiders são programas que navegam automaticamente por websites para coletar informações. Pensando no Google, um webspider feito pelo Google navega pelos links das páginas e alimenta uma base de dados do Google, que é usada para consultas durante as buscas realizadas pelos usuários.

Vamos parar e lembrar como funcionavam antigamente os sistemas de buscas como Yahoo!, Cade?, Aonde.com, dentre outros. Antigamente, nós precisávamos cadastrar os nossos sites e as palavras chave referentes ao site, para ele ser encontrado durante as buscas. Porém, o Google inovou na maneira de alimentar as bases de dados dele, usando webspider. Hoje, basta que um site esteja na internet e linkado para que ele apareça nas bases do Google, sem precisar de nenhum cadastro por parte do criador do site nas ferramentas de buscas. Porém, isso expôs muitas informações e para isso, foram criados os arquivos robots.txt.

Um webspider consulta o arquivo robots.txt que está localizado no diretório

raiz do website para saber quais arquivos ele não deve analisar. Portanto, os arquivos ou diretórios que estão listados em um arquivo robots.txt não aparecerão nos resultados das buscas realizadas em sites como o Google.

Vamos a um exemplo:



<http://www.oys.com.br/robots.txt>

Portanto, os arquivos robots.txt podem revelar para nós informações sobre arquivos e diretórios que poderíamos não conhecer e até mesmo não estar linkado no site.

Mais informações sobre os arquivos robots.txt podem ser obtidas no site



<http://www.robotstxt.org/orig.html>

5.8. Netcraft

Netcraft é uma empresa europeia que prove serviços de internet. Dentro de alguns serviços que ela fornece está a análise de mercado para empresas de web hosting e servidores web, incluindo detecção do sistema operacional e versão do servidor web, e em alguns casos, informações sobre uptime do servidor, já que normalmente esse fator é determinante na escolha de uma empresa de hospedagem de sites.

Para nós, pode ser útil para exibir a versão do sistema operacional e servidor web que um determinado host está usando, além de manter um histórico das versões que o mesmo host já usou anteriormente.



<Http://www.netcraft.com>

5.9. Buscando relacionamentos

Através de relacionamentos encontrados na web, podemos conseguir mais informações de nosso alvo.

Informações de relacionamentos podem ser encontradas em site com links para o site do alvo, sites secundários que tem relação com o site principal do alvo, companhias que fazem negócios ou estão sob a mesma administração que nosso alvo e etc.

Essas servem para entendermos melhor como a organização trabalha, se possui outros ramos de atividades, organizações “irmãs” e parcerias. Com tais informações em mãos, e um melhor conhecimento da estrutura organizacional, podemos, inclusive, realizar ataques de engenharia social mais eficazes.

O Google nos fornece alguns operadores que nos auxiliam nessa busca, e que já estudamos anteriormente. São eles:

- info
- link
- related



<http://www.unmaskparasites.com/>

5.10. Prática dirigida

Vamos realizar algumas consultas!

A partir do site www.oys.com.br consiga o máximo de informações possíveis a partir dos seguintes comandos:

- Whois : retornará o resultado da consulta à entidade responsável pelos registros de domínio, no nosso caso o registro.br. Conseguiremos

nome dos responsáveis, telefone, CPF ou CNPJ, endereço, e-mail e etc.

- Dig : conseguiremos informações sobre os servidores onde o domínio está hospedado. Teremos o endereço do servidor de domínio e de e-mail, por exemplo.
- Nslookup : retornará o IP do domínio e o nome do mesmo, incluindo a porta a partir da qual o servidor está respondendo (no caso do DNS, a padrão é a 53).
- www.netcraft.com : permite que saibamos qual sistema operacional o servidor está executando com uma proximidade próxima da certeza. Além disso, conseguiremos o nome do servidor, endereço IP, país onde o mesmo está localizado, servidor de DNS, e se digitarmos apenas o domínio (oys.com.br), encontraremos sites relacionados ao mesmo domínio, como netclass.oys.com.br, por exemplo.
- www.123people.com : esse site não busca informações sobre domínio, mas sobre pessoas. Na consulta com o whois obtivemos alguns nomes, e nesse site podemos consultar as referências na web acerca desse nome (notícias, artigos, postagens relevantes).

Com cada um desses comandos e sites, conseguiremos algumas informações diferentes, que nos ajudarão na próxima fase de nosso teste.

5.11. Rastreamento de E-mails

A análise de e-mails é normalmente feita pela área de Forense Computacional. Porém, podemos usar um e-mail para obter informações sobre o host da pessoa, quando esse não é de conhecimento do atacante e precisa ser descoberto, pois é um possível alvo.

O correio eletrônico é dividido em duas partes: Cabeçalho (Header) e Corpo (Body) do e-mail. No cabeçalho é onde encontramos diversos campos com informações de controle, destinatário, remetente, data de envio, dentre outras informações.

E é no corpo da mensagem que encontramos a mensagem, em si.

De acordo com a Rfc 2821 / 2822 , temos os seguintes campos presentes no cabeçalho de um e-mail:

Campos de origem:

- “From:” - autor da mensagem
- “Sender:” - remetente da mensagem
- “Reply-to:” - e-mail sugerido pelo autor da mensagem para que as respostas sejam enviadas

Campos de destino:

- “To:” - endereço dos receptores primários da mensagem
- “Cc:” - Carbon Copy - receberão uma cópia da mensagem, com o e-mail visível para todos
- “Bcc:” - Blind Carbon Copy - receberão uma cópia da mensagem, sem ter o e-mail visível para todos

Campo de data de origem:

- “Date:” - Hora da criação da mensagem

Campos de identificação:

- “Message-ID:” - Identificador de mensagem único. Valor único determinado pelo servidor que transmite a mensagem;
- “In-Reply-To:” - Usado quando uma mensagem é respondida. Identificador da mensagem respondida;
- “References:” - Usado quando uma mensagem é respondida. Referências.

Campos de informação:

- “Subject:” - Assunto da mensagem;

- “Comments:” – Comentários sobre a mensagem;
- “Keywords:” – Palavras chaves relacionadas à mensagem;

Campos de Rastreamento:

- “Return-Path:” – Caminho de volta da mensagem para o remetente. Esse campo é adicionado pelo último MTA que entrega o e-mail ao destinatário
- “Received:” – Contém informações para ajudar na análise de problemas com a entrega e recebimento das mensagens. Todo e-mail possui pelo menos um campo “Received”, que é adicionado por cada servidor onde a mensagem passa.

O campo que interessa a nós é o campo “Received:”, que contém informações sobre o endereço IP de onde a mensagem de correio eletrônico partiu.

Vamos ver um exemplo de cabeçalho:

Teste de cabeçalho de e-mail

Sexta-feira, 7 de Maio de 2010 11:56

From Luiz Vieira Fri May 7 14:56:10 2010

X-Apparently-To: loki_br@yahoo.com.br via 67.195.8.190; Fri, 07 May 2010 07:56:36 -0700

Return-Path: <luizwt@gmail.com>

X-YMailISG:

D22GN8EWLDv3S52h.i1n2Q_RMHotyj8fEgkpy6vkLjqgVXe0ou9d8z3JRi_HzPp9ulv8sGxKEFuZJoSGKEjcmpQKNgO2IEl06u
KtpgmsDoJngYof4JakGFNaN1rFAYx38yNwtzkVfpF2P.auE.DUqmghkbpAdApCKdbiMNDQFExwnwGoVq1JMTx5jQ0ANyS4z
3P1M.0_4_0u2Ne7sbg13Oq9yPuH6b5f4GC6A2lj0QPOF2Vg.u9Ct5IGztq4lchdE.wFCewHWVdxY_vmYz2Xxc.Br1ycrag1E08l
d1tMTdaF2f7kU1ORu0KAdxm1y72YWXpIL84c2uXX0AKYWgZPoA6O37lvV6IwkLQXT8fQ7AezVgr7DHPbIQelfinVguXw
mCDFsmCicAx5ph2060NUgA4qah19chxRRGbT12Q9pkkYaO3iVv2fZQuG8lXedP7dzXJMOwX2GTDm1wNAUfAp.z0SA--

X-Originating-IP: [209.85.217.219]

Authentication-Results: mta1079.mail.sk1.yahoo.com from=gmail.com; domainkeys=pass (ok); from=gmail.com;
dkim=pass (ok)

Received: from 127.0.0.1 (EHLO mail-gx0-f219.google.com) (209.85.217.219) by mta1079.mail.sk1.yahoo.com
with SMTP; Fri, 07 May 2010 07:56:36 -0700

Received: by mail-gx0-f219.google.com with SMTP id 19so660108gxk.0 for <loki_br@yahoo.com.br>; Fri, 07
May 2010 07:56:35 -0700 (PDT)

DKIM-Signature: v=1; a=rsa-sha256; c=relaxed/relaxed; d=gmail.com; s=gamma; h=domainkey-

signature:received:mime-version:from:date:message-id:subject:to:content-type;

bh=zsRzXjYMy4NDiWycSOHoC4K65BBPQ2mLafsg2/kxiuw=;

b=CYkBO1Xf3yKkxCEx7UvNmaW/cWNEMA/r36T4PB1JSK5eVKUJo9C9hR4swWXwiR7viL

TVSM2su9lxQEDeze7exMMS3AMjyhRxzp7QQ68bZ4xoBVuR0RYVikWUTszHt4dykALpDj

jW9xejN3sknjCsTFUp2ObbUqiA6gpELFcIW2I=

DomainKey-Signature: a=rsa-sha1; c=noaws; d=gmail.com; s=gamma; h=mime-version:from:date:message-id:subject:to:content-type; b=Med0d9Uy5GBRwXazfwundBvqX1ZJNUH8VoLiZhudCurMouAQscyQz5mxE/ig1cyH0Lqe9J5pqC2yz7SNjwoqR0eaPVGwRfdg/PCN6DN9isKvYhVZqKdv9JUVKSAFRZSZ60RswaSHUIJcbqyPXhPXyK6GKNDBAKTC3Ty/4ZnKEXE=
Received: by 10.150.243.17 with SMTP id q17mr4368907ybh.103.1273244190925; Fri, 07 May 2010 07:56:30 -0700 (PDT)
MIME-Version: 1.0
Received: by 10.151.8.14 with HTTP; Fri, 7 May 2010 07:56:10 -0700 (PDT)
From: Este remetente é verificado pelo DomainKeys
Luiz Vieira <luizwt@gmail.com>
Adicionar remetente à lista de contatos
Date: Fri, 7 May 2010 11:56:10 -0300
Message-ID: <r2v4da582081005070756pc0de571fu78a59b6aa99d4bb2@mail.gmail.com>
Subject: =?ISO-8859-1?Q?Teste_de_cabe=E7alho_de_e=2Dmail?=
To: loki_br@yahoo.com.br
Content-Type: multipart/alternative; boundary=000e0cd29860b6e12e04860243f6
Content-Length: 482

Na do cabeçalho sublinha e em negrito, encontramos o IP de quem enviou essa mensagem, no caso o IP 10.151.8.14 . No cabeçalho podemos encontrar vários campos Received, pois por cada servidor de e-mail que a mensagem passa é adicionado um novo campo. Porém, o endereço de quem enviou a mensagem vai aparecer no campo Received mais baixo, no exemplo acima, o último Received de nosso cabeçalho, pois cada servidor de e-mail que adiciona esse campo vai colocando sempre acima do primeiro campo adicionado.

E como podemos obter o cabeçalho de um e-mail?

No Yahoo! Basta clicarmos em “Cabeçalhos Completos”.



—
Luiz Vieira
luizwt@gmail.com
<http://hackproofing.blogspot.com/>
+55 21 8746-6287



5.12. Fingerprint

Fingerprint é uma das principais técnicas de levantamento de informação (footprint) que é realizada por um Pen-Tester antes que o mesmo comece a realizar os ataques em seu alvo.

A função dessa técnica é identificar a versão e distribuição do sistema operacional que irá receber a tentativa de intrusão. Sendo assim, essa técnica é extremamente importante para que o atacante consiga desenvolver de maneira mais precisa e menos ruidosa seu ataque. Usando essa técnica o Pen-Tester estará explorando problemas da pilha TCP/IP e verificando características únicas que permitem que o sistema alvo seja identificado.

Só depois que isso for feito, poderão ser escolhidas as melhores ferramentas para explorar o sistema.

Para que o fingerprint apresente resultados confiáveis são necessárias análises complexas, como:

- Analise de pacotes que trafegam pela rede;
- Leitura de banners (assinaturas do sistema);
- Análise de particularidades da pilha TCP/IP.

Para realizar tais análises, podemos utilizar ferramentas específicas, conhecidas como scanners de fingerprint, que são softwares usados para realizar tarefas de detecção de sistemas operacionais.

Entre os scanners existentes, podemos dividi-los basicamente em dois tipos:

5.12.1. Fingerprint passivo

O scanner atua como um “farejador” na rede, ou seja, fica escutando os pacotes que passam por ela, detectando o formato do pacote que está passando consegue identificar o sistema operacional.

Para esse tipo de operação, utilizamos a ferramenta `p0f`, que permite

“farejarmos” os pacotes que trafegam na rede.



```
#p0f -i eth0 -o log
```

Com o parâmetro `-i` definimos em qual dispositivo de rede ele ficará farejando os pacotes, se não definimos nada, ele assume “all”, farejando todos os dispositivos disponíveis.

Com o parâmetro `-o`, dizemos para o p0f armazenar tudo o que for capturado em um arquivo de saída, com nome definido por nós.

5.12.2. Fingerprint ativo

O scanner envia pacotes manipulados e forjados, baseado em uma tabela própria de fingerprint. Com isso, ele analisa a resposta do pacote e compara com a tabela, para definir qual o sistema operacional.

O risco desse tipo de fingerprint, é que se o alvo estiver com um firewall bem configurado e um IDS/IPS, nosso acesso pode ser logado em seu sistema e pode ser difícil que consigamos muitas informações.

Duas ferramentas que podemos utilizar em um fingerprint ativo são nmap e xprobe2, além, obviamente, dos comandos ping e traceroute, só para citarmos dois comandos básicos.

5.12.3. Descobrindo um Sistema Operacional usando ICMP

Um simples ping é capaz de revelar o sistema operacional de uma máquina.

```
# ping www.oys.com.br -c 1
PING www.oys.com.br (xx.xx.xx.xx) 56(84) bytes of data.
64 bytes from 41-142-118-66.reverse.priorityonline.net (xx.xx.xx.xx): icmp_seq=1 ttl=49
time=1452 ms
--- www.oys.com.br ping statistics ---
1 packets transmitted, 1 received, 0% packet loss, time 0ms
rtt min/avg/max/mdev = 1452.515/1452.515/1452.515/0.000 ms
#
```

A informação importante está no campo TTL (Time To Live). A maioria dos sistemas operacionais se diferencia pelo valor retornado de TTL. Veja a lista abaixo:

- Cyclades - Normalmente 30
- Linux - Normalmente 64
- Windows - Normalmente 128
- Cisco - Normalmente 255
- Linux + iptables - Normalmente 255

5.12.4. Calculando HOP

Utilizando os comandos traceroute e ping conjugados para obter informações, podemos calcular o ttl e descobrir o sistema operacional do alvo.

```
# traceroute www.oys.com.br
traceroute to www.oys.com.br (xx.xx.xx.xx), 30 hops max, 60 byte packets
 1 192.168.0.5 (192.168.0.5) 0.159 ms 0.146 ms 0.147 ms
 2 c906ff01.static.spo.virtua.com.br (201.6.255.1) 8.615 ms 8.617 ms 8.663 ms
 3 c906005e.virtua.com.br (201.6.0.94) 8.435 ms 8.501 ms 8.503 ms
 4 c9060006.virtua.com.br (201.6.0.6) 8.942 ms 9.022 ms 9.031 ms
 5 c906000d.virtua.com.br (201.6.0.13) 9.431 ms 9.502 ms 13.104 ms
 6 64.209.108.225 (64.209.108.225) 21.273 ms 17.076 ms 17.344 ms
 7 * * *
 8 border2.tge3-1-bbnet1.acs002.pnap.net (64.94.0.19) 175.501 ms 176.185 ms 177.297
ms
 9 sagonet-2.border2.acs002.pnap.net (70.42.180.150) 135.368 ms 135.402 ms 136.298
ms
10 ve40.core01a.tpa.sagonet.net (63.246.159.41) 146.523 ms 146.574 ms 146.557 ms
11 gige1.ds03a.tpa.sagonet.net (65.110.32.10) 147.590 ms 147.738 ms 148.665 ms
12 * * *
```

Com o traceroute podemos ver que temos 11 saltos, até que os pacotes são interrompidos, o que pode representar um firewall ou algo do tipo que descarte os

pacotes.

Agora que sabemos por quantos roteadores estamos passando, podemos usar o comando ping para descobrir o TTL do site.

```
# ping www.oys.com.br -c 1
PING www.oys.com.br (xx.xx.xx.xx) 56(84) bytes of data.
64 bytes from 41-142-118-66.reverse.priorityonline.net (xx.xx.xx.xx): icmp_seq=1 ttl=49
time=1452 ms
--- www.oys.com.br ping statistics ---
1 packets transmitted, 1 received, 0% packet loss, time 0ms
rtt min/avg/max/mdev = 1452.515/1452.515/1452.515/0.000 ms
#
```

Somando a quantidade de saltos (11) com o valor de ttl (49), temos 60. O mais próximo de 60 é 64, que representa o Linux. A partir daí, podemos concluir que o sistema operacional utilizado no servidor onde o site está hospedado é Linux.

5.12.5. Fingerprint através do xprobe2

Ferramenta para fingerprint ativo apresentada na conferencia BlackHat Las Vegas em 2001 criada por Fyodor criador da ferramenta nmap e Ofir Arkin co-fundador do projeto honeynet.org.

Seu banco de dados de assinaturas fica em:



```
/usr/local/etc/xprobe2/xprobe2.conf
```

Execute o xprobe2 na máquina do instrutor para descobrir o sistema operacional:



```
# xprobe2 www.oys.com.br
```

Agora tente utilizar o fingerprint sobre uma porta aberta:



```
# xprobe2 -p tcp:80:open 66.118.142.41
```

Percebe-se que quanto maior o número de informações que passamos para o xprobe2, maior é a precisão no reconhecimento do Sistema Operacional do alvo.

5.13. Contramedidas

- Configurar as aplicações instaladas nos servidores, atentando para as informações que elas exibem durante as requisições.
- Configurar corretamente as regras de firewall para bloquear requisições maliciosas.
- Ter cuidado com as informações publicadas na WEB.
- Configurar corretamente o arquivo robot.txt, para que diretórios com arquivos sensíveis não sejam indexados pelos sistemas de busca.

5.14. Prática dirigida

1. Faça uma varredura no servidor da OYS usando a ferramenta dnsenum.
2. Identifique na internet um arquivo robots.txt
3. Identifique a versão do sistema operacional de um servidor local da rede utilizando o nmap e xprobe2
4. Utilizando a ferramenta p0f, identifique o sistema operacional de máquinas existentes na rede local